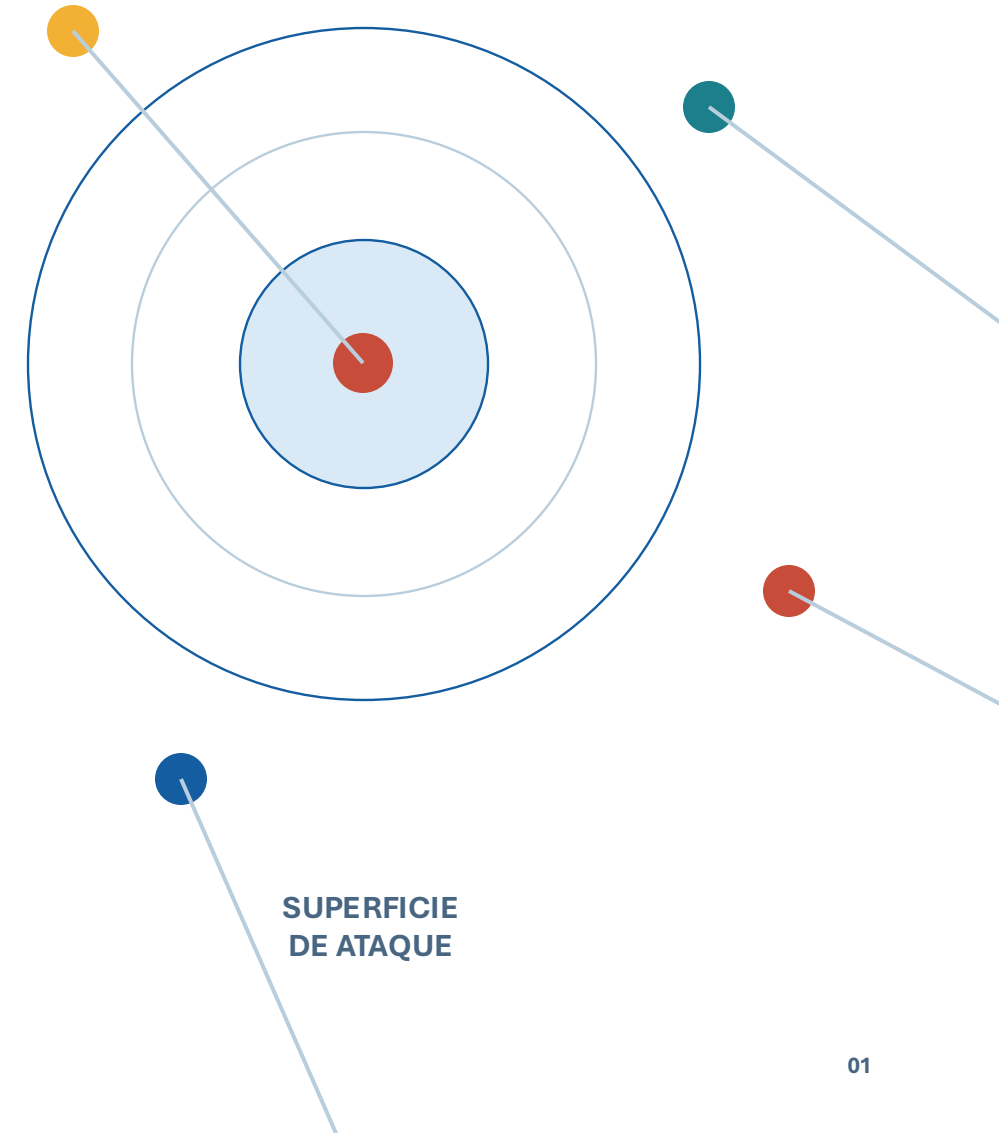


Vectores de amenaza y filtraciones de datos

Cómo proteger identidades, correo, dispositivos y datos en Microsoft 365

PREVENIR · DETECTAR · RESPONDER



Un vector conecta una técnica con un activo valioso



Camino o medio utilizado para acceder, engañar, ejecutar o extraer.

La defensa comienza identificando la ruta, el activo objetivo y la consecuencia.

La Kill Chain ofrece siete oportunidades para interrumpir el ataque



Principio operativo: aplicar controles en cada etapa obliga al atacante a superar múltiples barreras.

La nube amplía la superficie que debe protegerse

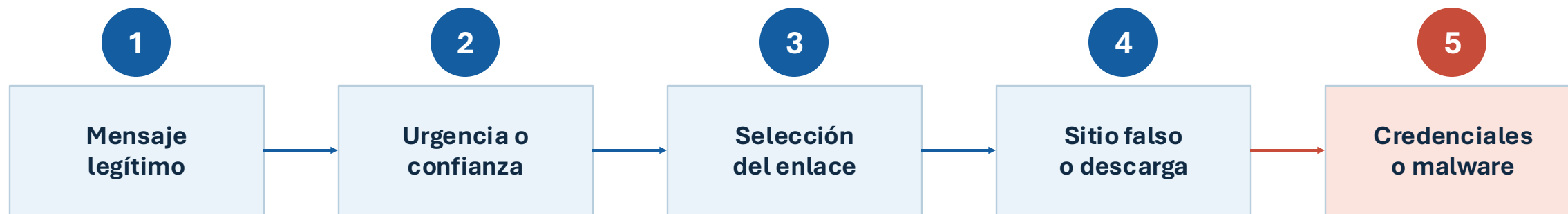


Los controles perimetrales locales ya no cubren todo el recorrido de los datos.

Defensa transversal

MFA · Conditional Access · EOP/Defender · DLP · auditoría y SIEM

El phishing transforma confianza y urgencia en una acción riesgosa

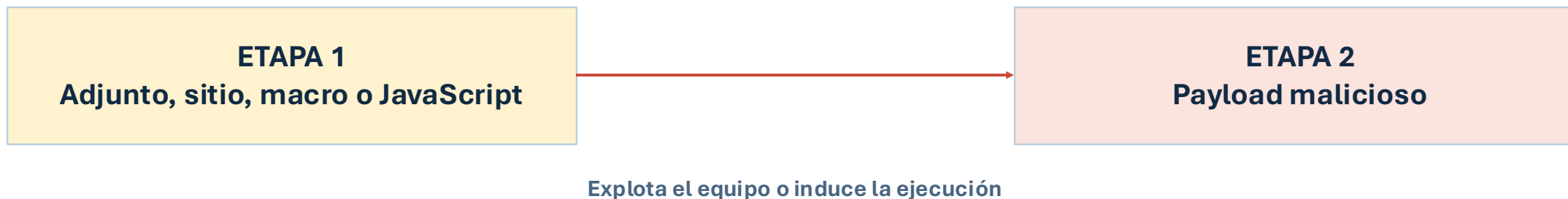


SEÑALES RECURRENTES

- Branding aparentemente legítimo
- URL que parece confiable
- Solicitud de información sensible
- Enlace o adjunto ejecutable

El malware suele entregarse en dos etapas

CADENA DE ENTREGA



VIRUS

Se replica modificando otros programas.

TROJAN HORSE

Abre una puerta trasera, roba e instala.

ROOTKIT

Mantiene acceso administrativo oculto.

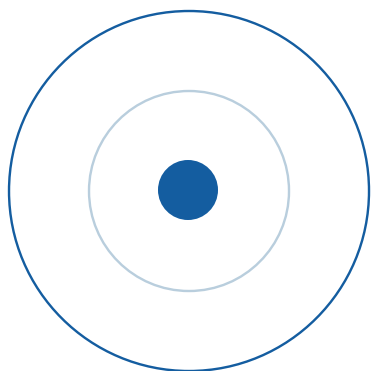
SPYWARE

Captura actividad, teclas y credenciales.

Spear phishing y whaling aumentan la precisión del engaño

SPEAR PHISHING

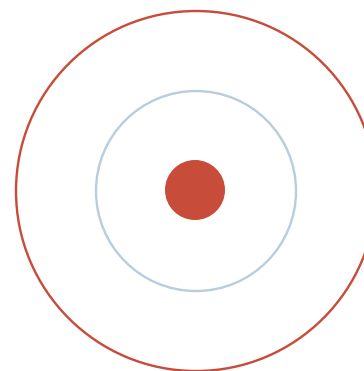
Individuo específico



Personalización por rol,
relación o contexto

WHALING

Ejecutivos y alto perfil



Impacto económico y
autoridad aparente

Más contexto del objetivo → mayor credibilidad → mayor probabilidad de acción

El spoofing explota la diferencia entre remitente técnico y visible

DOS IDENTIDADES DEL REMITENTE



El atacante busca que la identidad visible parezca confiable aunque el origen no lo sea.

EOP

Exchange Online Protection analiza automáticamente el correo entrante y utiliza spoof intelligence como parte de la defensa contra phishing.

También existen usos legítimos: terceros autorizados, asistentes, aplicaciones y listas.

El volumen de correo puede ocultar enlaces y adjuntos maliciosos

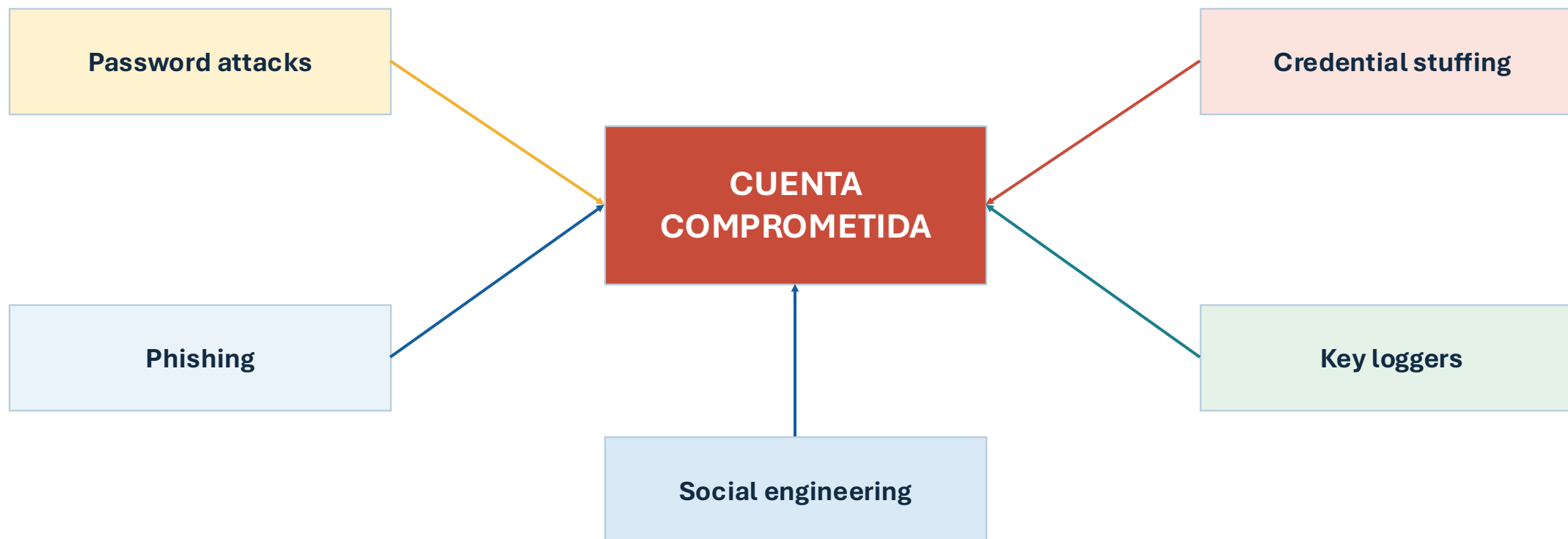


Spam y bulk email: afectan productividad.

Malware: convierte ese mismo canal en una vía de ejecución.

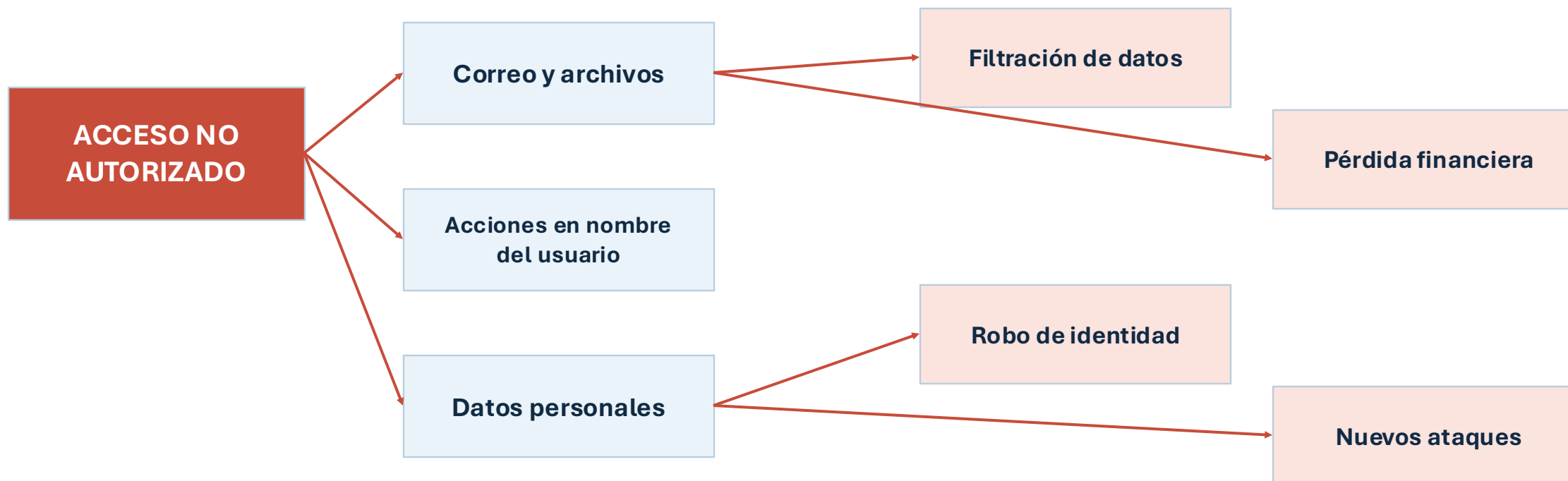
La diferencia crítica no es el volumen: es la intención y el payload.

Cinco rutas convergen en el compromiso de una cuenta



Credenciales débiles, robadas, reutilizadas o capturadas son el punto común.

Una cuenta comprometida se convierte en plataforma de ataque



Contener la sesión no basta: hay que revisar lo que la identidad pudo leer, cambiar y delegar.

La mitigación efectiva superpone identidad, privilegios, telemetría y datos

1 IDENTIDAD

MFA / 2FA · contraseñas únicas · Entra ID Protection

2 ACCESO

Least privilege · revisión de permisos · Conditional Access

3 DETECCIÓN

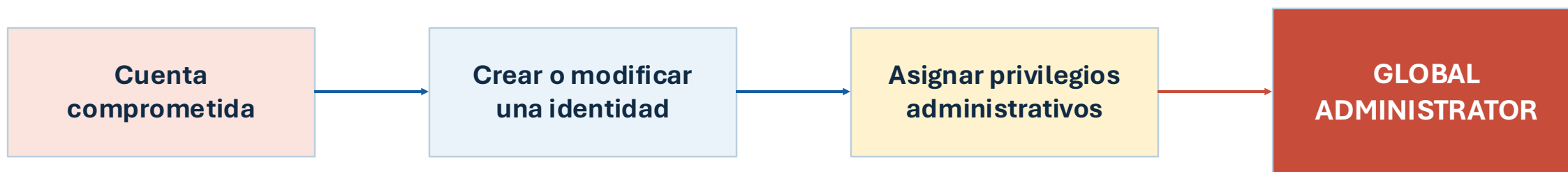
Activity Logs · alertas · SIEM · monitoreo continuo

4 DATOS Y RESPUESTA

TLS · DLP · cifrado · patching · plan de incidentes

Recomendación: priorizar MFA; la expiración periódica no contiene una credencial ya comprometida.

La elevación de privilegios busca control administrativo persistente



2-5

Global Administrators recomendados por tenant

MFA en administradores

Revisión periódica

Auditoría y alertas

Riesgo táctico

“Ocultarse a plena vista” con una cuenta administrativa nueva.

Después del compromiso, la evidencia está en identidad, configuración y datos

IDENTIDAD

- ✓ Nuevas cuentas
- ✓ Cuentas modificadas
- ✓ Promociones a Global Admin

CONFIGURACIÓN

- ✓ Cambios globales
- ✓ Permisos y ACL
- ✓ Delegación de buzones

DATOS Y MENSAJERÍA

- ✓ Interacciones con datos
- ✓ Reglas de forwarding
- ✓ Reglas de transporte

Preservar evidencia antes de corregir acelera el análisis y evita perder contexto.

La exfiltración combina acceso, movimiento y monetización

DATOS DE INTERÉS

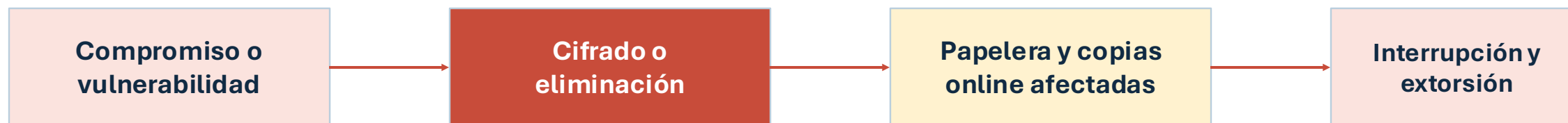


CONTROLES



Objetivo: limitar quién accede, qué puede mover y dónde puede compartir.

La eliminación de datos busca negar la recuperación



RANSOMWARE

MFA + RBAC

limitar acceso y eliminación

Alertas

detectar sesiones y borrados

Patching + Defender

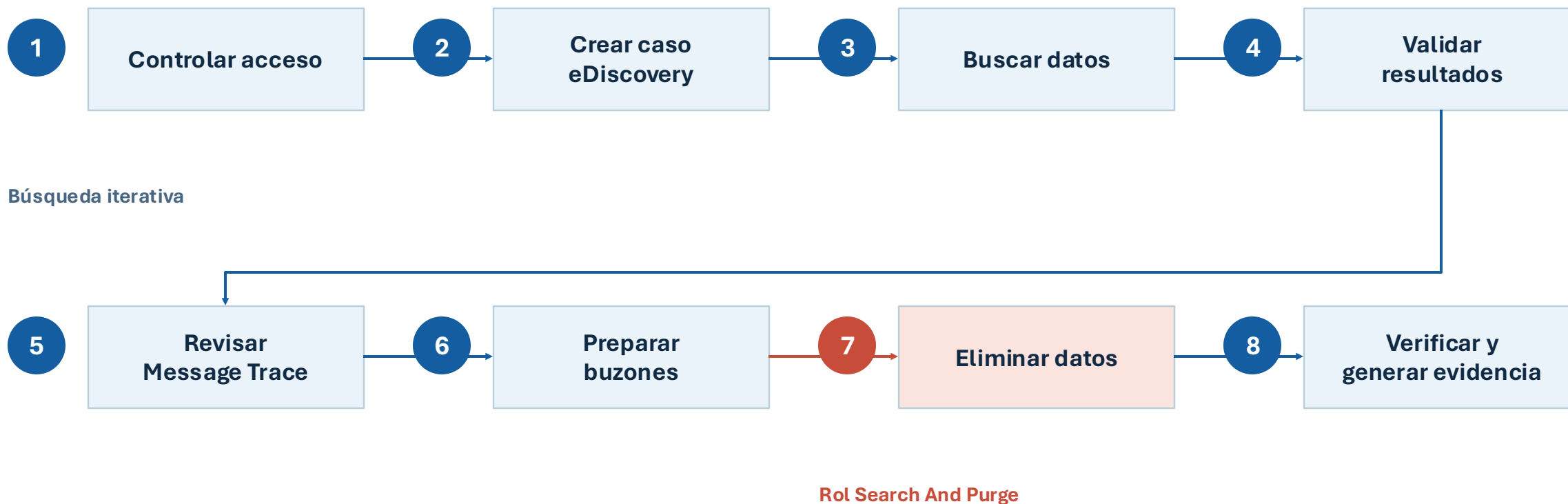
reducir ejecución maliciosa

BACKUP OFFLINE

restaurar fuera de las cuentas online

La redundancia de Microsoft 365 favorece disponibilidad; no sustituye la copia offline de datos críticos.

Un incidente de data spillage exige ocho pasos controlados



Cerrar el caso solo después de confirmar cero resultados y conservar evidencia.

La investigación tiene límites operativos que condicionan la estrategia

1.000

mensajes previsualizables
como muestra aleatoria

10.000

resultados simultáneos con
eDiscovery Premium y licencias
elegibles

30

días de Message Trace en
tiempo real

90

días de datos históricos de
Message Trace

DECISIONES DE INVESTIGACIÓN

- Dividir resultados por palabra clave, fecha, remitente o destinatario.
- Revisar destinatarios para determinar si hubo intercambio externo.
- Eliminar consultas que contengan el dato sensible usado como criterio.
- Usar OCR, threading, etiquetado y predictive coding cuando corresponda.

Message Trace ayuda a reconstruir el recorrido, pero no garantiza resultados exhaustivos.

Password cracking e insiders requieren controles distintos

PASSWORD CRACKING

Alta velocidad contra credenciales débiles

- Contraseñas cortas, comunes o reutilizadas.
- Smart password lockout en Entra ID sin federation.
- Ajustar umbrales según el directorio y el riesgo.

MALICIOUS INSIDER

Acceso legítimo con intención ilícita

- Puede crear backdoors, exfiltrar o eliminar.
- El privilegio administrativo amplifica el impacto.
- Controlar acceso, auditoría y salida de personal.

Automatización externa y conocimiento interno son riesgos diferentes: medirlos igual deja brechas.

Proteger, detectar y responder cierra el ciclo

PROTEGER

- 1 MFA y Conditional Access
- 2 Least privilege y RBAC
- 3 EOP / Defender / DLP

DETECTAR

- 1 Entra ID Protection
- 2 Activity Logs y SIEM
- 3 Alertas de sharing y borrado

RESPONDER

- 1 Contener sesiones y privilegios
- 2 Investigar con eDiscovery
- 3 Eliminar, restaurar y documentar

DEFENSA EN PROFUNDIDAD

Ningún control aislado detiene todos los vectores.